Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 2.1 / COMPANION WORKBOOK

Risk Management Framework

Prepare, Categorize, and Select

Take the network the Build the Network courses (1.1–1.19) create, the system shown in Inside the Network, through the Prepare, Categorize, and Select steps of the Risk Management Framework (RMF), following NIST SP 800-37 Revision 2 with the April 2016 Joint Special Access Program Implementation Guide (JSIG) mapped in. Define and register the system, describe and categorize it in a draft System Security Plan, and select its controls with a draft risk assessment and a monitoring strategy, ready for the Body of Evidence in course 2.2.

MATERIALS EDITION 2.0 / COURSE 2.1

Updated 15 October 2026 · sbd-rmf

NAME _____ / DATE _____

© 2026 Secure By Design Team LLC.

START HERE / YOUR LEARNING PATH

Table of contents

Read each module alongside the interactive course. Use the record tables to write down what you actually produce — the workbook is your record, not the course.

Before you start

RMF steps, tasks, and outputs

01 RMF roles, steps, and editions

02 Define and register the system

03 Describe and categorize the system

04 Select controls and plan monitoring

Evidence starters

Knowledge check answers

Sources

Course review and sign-off

> **HOW TO USE IT** Each module page has the same shape: its RMF step with the NIST SP 800-37 Rev. 2 and JSIG tasks and outputs, three short lessons, a worked example, the practice output, and a record table. Fill the tables from your own records — never from the sample values.

© 2026 Secure By Design Team LLC.

Before you start

Take the network the Build the Network courses (1.1–1.19) create, the system shown in Inside the Network, through the Prepare, Categorize, and Select steps of the Risk Management Framework (RMF), following NIST SP 800-37 Revision 2 with the April 2016 Joint Special Access Program Implementation Guide (JSIG) mapped in. Define and register the system, describe and categorize it in a draft System Security Plan, and select its controls with a draft risk assessment and a monitoring strategy, ready for the Body of Evidence in course 2.2.

Prerequisites

- ☐ Basic security and system administration knowledge. No commercial tool access is required.
- ☐ Your Inside the Network build from Build the Network (courses 1.1–1.19), or the supplied sample records; the samples are enough to complete the course.
- ☐ The governing direction for your practice: NIST SP 800-37 Revision 2 and, for a Special Access Program (SAP) system, the JSIG or successor your program directs. This course uses the public April 2016 JSIG.

What this course covers

- Explain RMF roles and how NIST SP 800-37 Revision 2 and the 2016 JSIG organize the steps and their outputs.
- Prepare, register, describe, and categorize the Inside the Network practice system.
- Select, tailor, and allocate controls with a draft Risk Assessment Report and a monitoring strategy for plan approval.

Practice artifacts in this course

- System scope record — Agree on the roles, governing direction, mission, boundary, information, early risks, and requirements before the package grows. Module 01 starts it, module 02 completes the Prepare fields, and module 03 adds the categorization basis.
- System registration — Register the system with the office the organization or program designates, so it is known, tracked, and accountable before the package grows. NIST registers in Prepare (P-18); the JSIG in Categorize (Task 1-3).
- System Security Plan — Describe the system and its categorization, record the plan’s approval, and explain how each selected control is implemented.
- Security Controls Traceability Matrix — Record each selected control’s source, tailoring, parameters, allocation, and inheritance, then trace it to implementation, evidence, and results. Started in Select; module 05 adds the as-implemented statements.
- Risk Assessment Report — Record the risks that remain with the selected controls, how likely and harmful each is, and what the assessment must confirm. Drafted in Select as a JSIG Step 2 output; module 08 updates it with assessment results.
- Continuous monitoring strategy — Define what is monitored, how often, by whom, and what triggers action, so the authorization basis stays current. Written in Select (S-5; JSIG Task 2-3) and run in module 12.

© 2026 Secure By Design Team LLC.

RMF steps, tasks, and outputs

Each module follows one Risk Management Framework (RMF) step in NIST SP 800-37 Revision 2 order, with the matching tasks and outputs of the Joint Special Access Program Implementation Guide (JSIG), 11 April 2016.

MODULE	RMF STEP	NIST	JSIG
01 RMF roles, steps, and editions	Foundations	—	—
02 Define and register the system	Prepare	P-1–P-18	—
03 Describe and categorize the system	Categorize	C-1–C-3	1-1–1-3
04 Select controls and plan monitoring	Select	S-1–S-6	2-1–2-4

TWO DOCUMENTS, ONE SEQUENCE NIST SP 800-37 Revision 2 has seven steps, starting with Prepare. The 2016 JSIG follows Revision 1’s six steps, from Categorize to Monitor, with SP 800-53 Revision 4 and CNSSI 1253 (March 2014). Confirm whether your program directs the JSIG, its successor, or other guidance.

© 2026 Secure By Design Team LLC.

RMF roles, steps, and editions

WHY THIS MATTERS Explain who performs, assesses, and approves Risk Management Framework (RMF) work, and how NIST and the Joint Special Access Program Implementation Guide (JSIG) organize its steps and outputs.

The RMF step

Who does the work NIST names roles by function (system owner, control assessor, common control provider, authorizing official); the JSIG uses SAP titles for the same work (ISO, SCA, CCP, AO) alongside the ISSM, ISSO, ISSE, and PSO. In both, only the AO accepts risk.

What this module produces

- A role map of who performs, assesses, and approves the work, in NIST and JSIG terms (the role assignments NIST covers in Task P-1)
- A record of the governing documents and editions: SP 800-37 Revision 2, the April 2016 JSIG or the successor your program directs, and the adopted SP 800-53 release
- The scope record, started with those roles and that governing direction

WHERE THE JSIG AND NIST DIFFER The JSIG of 11 April 2016 follows SP 800-37 Revision 1's six steps, starting at Categorize, with SP 800-53 Revision 4 and CNSSI 1253 (March 2014). Prepare is the NIST Revision 2 addition. DoDM 5205.07 refers to the JSIG or its successor.

Learn

01.1 Risk and the authorization decision Start with the mission, then ask about risk.

The Risk Management Framework (RMF) connects a system's purpose to the safeguards, evidence, and decisions needed to operate it. Begin with what the organization needs the system to do. Then ask what could happen if its information is exposed, changed incorrectly, or unavailable.

Each step produces outputs the next one builds on, ending in an authorization package. An Authorization to Operate (ATO) is the authorizing official's decision about the risk that remains; installing tools or finishing a checklist doesn't make it.

01.2 Roles and accountability Everyone contributes. The responsibilities differ.

NIST names roles by function: system owner, control assessor, common control provider, and authorizing official. The Joint Special Access Program (SAP) Implementation Guide (JSIG) uses SAP titles for that work: Information System Owner (ISO), Security Control Assessor (SCA), Common Control Provider (CCP), and Authorizing Official (AO).

An Information System Security Manager (ISSM) oversees the security program, an Information System Security Officer (ISSO) supports day-to-day implementation, and an Information System Security Engineer (ISSE) designs security in; SAP programs add a Program Security Officer (PSO). Local appointments set the exact split. Only the AO accepts risk.

01.3 NIST, the JSIG, and their editions Know which document, and which edition, you're following.

© 2026 Secure By Design Team LLC.

NIST Special Publication (SP) 800-37 Revision 2 (December 2018) has seven steps: Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor. Each is a set of numbered tasks, such as P-11 for the authorization boundary, with expected outputs and responsible roles. SP 800-53 supplies the controls.

The JSIG of 11 April 2016 applies that foundation to SAP systems, with SP 800-53 Revision 4 and Committee on National Security Systems Instruction (CNSSI) 1253 of March 2014. It follows SP 800-37 Revision 1's six steps, so it has no Prepare step; its tasks run from 1-1 to 6-7, and each step lists its outputs.

The public JSIG is this 2016 edition. Department of Defense Manual (DoDM) 5205.07 refers to the JSIG or its successor, so confirm what your program directs. This course follows the NIST steps, maps the JSIG tasks into each, and notes where the two differ.

Worked example: From a claim to a decision

1. **Claim —** "Privileged account changes are logged and reviewed," as the System Security Plan (SSP) states it for the practice system.
2. **Evidence —** The control owners supply the event-forwarding configuration, a sample account change from SBD-DC01, and the analyst's review record in SBD-SPLUNK01.
3. **Assessment —** The assessor (SCA) tests the event and checks that the expected review happened.
4. **Decision —** The AO weighs the supported result and any remaining gap. Only the AO can accept the risk.

Build

Start the scope record. Map who holds each role for the practice system (system owner or ISO, ISSM, ISSO, ISSE, SCA, CCP, AO, and a PSO if assigned) and mark who performs, assesses, and approves. Record the governing documents and editions, the adopted control release, and privacy responsibilities.

Practice artifacts System scope record (see Evidence starters)

Think it through

Given a missing test result and an unresolved risk, identify who supplies the evidence, who assesses it, and who can accept the risk, in NIST and JSIG terms. Then explain why the 2016 JSIG has no Prepare step.

Check your understanding

Your program directs the public JSIG of 11 April 2016. Which statement fits it?

- A. It is built on SP 800-53 Revision 5 and begins with Prepare.
- B. It replaces NIST, so SP 800-37 no longer applies.
- C. It follows SP 800-37 Revision 1's six steps, starting at Categorize, with SP 800-53 Revision 4 and CNSSI 1253.

Your record

RECORD	YOUR OBSERVATION
System scope record — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Everything you built in Build the Network is one system with one mission. Course 2.1 takes it through Prepare, Categorize, and Select, so every later record and the authorizing official’s decision rest on the same defined system.

[1] NIST SP 800-37 Revision 2

[6] DoDM 5205.07

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Define and register the system

> **WHY THIS MATTERS** Establish what is being authorized and why: the mission, stakeholders, assets, boundary, information and its life cycle, early risks, and requirements. Then register the system.

The RMF step

Who does the work NIST gives the organization-level tasks (P-1 to P-7) to senior leaders and the risk executive function. At the system level, the mission or business owner and the system owner lead, the authorizing official determines the boundary (P-11), and the system owner registers the system (P-18). The 2016 JSIG has no Prepare step, so it assigns no roles here.

- NIST P-1 · Risk management roles
- NIST P-2 · Risk management strategy
- NIST P-3 · Risk assessment—organization
- NIST P-4 · Organizationally-tailored baselines and Cybersecurity Framework Profiles (optional)
- NIST P-5 · Common control identification
- NIST P-6 · Impact-level prioritization (optional)
- NIST P-7 · Continuous monitoring strategy—organization
- NIST P-8 · Mission or business focus
- NIST P-9 · System stakeholders
- NIST P-10 · Asset identification
- NIST P-11 · Authorization boundary
- NIST P-12 · Information types
- NIST P-13 · Information life cycle
- NIST P-14 · Risk assessment—system
- NIST P-15 · Requirements definition
- NIST P-16 · Enterprise architecture
- NIST P-17 · Requirements allocation
- NIST P-18 · System registration

The 2016 JSIG has no Prepare step.

What this module produces

- Mission and stakeholders, recorded in the scope record (P-8, P-9)
- An asset list and a documented authorization boundary, with dependencies and candidate common controls (P-10, P-11)
- Information types and their life cycle, including every boundary transfer (P-12, P-13)
- An early risk picture (P-14), carried into the draft Risk Assessment Report in module 04

© 2026 Secure By Design Team LLC.

- Requirements defined, placed in the architecture, and allocated to the system or its environment (P-15 to P-17)
- A registered system, recorded in the registration record (P-18)

> **WHERE THE JSIG AND NIST DIFFER** The 2016 JSIG has no Prepare step; it follows SP 800-37 Revision 1. It describes the system and its boundary (Task 1-2) and registers it (Task 1-3) in Categorize, and drafts its first Risk Assessment Report in Select. NIST does this work in Prepare (P-11, P-14, P-18).

Learn

02.1 Organization and mission Prepare starts above the system.

Prepare is the step NIST SP 800-37 Revision 2 added. Its organization-level tasks (P-1 to P-7) assign roles, set the risk strategy and tolerance, identify common controls systems can inherit, and set an organization-wide monitoring strategy. A system team works inside those decisions.

At the system level, start with the mission (P-8) and the stakeholders (P-9): what work the system supports, who depends on it, who owns its information, and what an interruption or misuse would affect.

02.2 Assets, boundary, and information Draw the boundary, then test the assumptions.

Identify the assets to protect (P-10), then the authorization boundary (P-11), which the authorizing official determines. It's more than a subnet diagram: consider management interfaces, hosting, shared services, information flows, and dependencies.

List the information types the system processes, stores, and transmits (P-12), and follow each from creation to disposal (P-13). A component outside the boundary can still affect risk. Record the relationship and the responsible party; don't use the boundary to make a hard dependency disappear.

02.3 Risk, requirements, and registration Assess early, allocate the requirements, then register.

Assess system risk early (P-14): threats, weaknesses, and likely consequences, so the requirements can answer them. Then define the security and privacy requirements (P-15), place the system in the enterprise architecture (P-16), and allocate each requirement to the system or its environment (P-17).

Last, the system owner registers the system with the office the organization designates (P-18). The 2016 JSIG has no Prepare step, so it describes the system and its boundary and registers it in Categorize (Tasks 1-2, 1-3), and drafts its first Risk Assessment Report (RAR) in Select.

Worked example: Resolve a boundary question

1. **Question —** Are the seven hypervisor hosts that run the enclave's servers covered by this authorization?
2. **Record —** List SBD-HV01 to SBD-HV07, who administers them, and the systems each one runs, including the domain controllers and the issuing CA.
3. **Resolve —** They can control the domain controllers, so they are Tier 0 assets wherever the line falls. Propose inside or external with the reason, and route it to the authorizing official, who determines the boundary (P-11).
4. **Prove —** Keep the asset list, boundary diagram, scope record, and registration consistent with the decision.

Build

Complete the scope record's Prepare fields for the practice system: mission and stakeholders, assets and boundary, information types and life cycle, the early risk picture, and requirements and allocation. Check each information flow against the connection map in Inside the Network, which shows every permitted, pending, and denied rule for a system. Then fill in the registration record.

Practice artifacts System scope record; System registration (see Evidence starters)

Think it through

Explain whether a hypervisor host, the core switch's management, a shared service, or an offline update transfer is inside the boundary, external, or inherited, with the supporting responsibility evidence. Say what changes in the registration if the boundary moves.

Check your understanding

Your program follows the 2016 JSIG, which has no Prepare step. Where does the boundary and registration work happen?

- A. In Categorize: describe the system and its boundary (Task 1-2), then register it (Task 1-3).
- B. Nowhere. Without a Prepare step, the JSIG skips it.
- C. In Monitor, once the system is operating.

Your record

RECORD	YOUR OBSERVATION
System scope record — location and version	
System registration — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Draw the boundary around the eight VLANs and the offline root CA, then trace each information flow across it. The hypervisor hosts, shared services and offline media transfers each need a recorded decision: inside, external, or inherited.

[1] NIST SP 800-37 Revision 2

[5] DoDI 8510.01

[6] DoDM 5205.07

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Describe and categorize the system

WHY THIS MATTERS Describe the system, justify its confidentiality, integrity, and availability impacts in the draft System Security Plan (SSP), and route the categorization for approval. Treat privacy applicability as an explicit decision.

The RMF step

Who does the work The system owner describes the system (C-1) and categorizes it with the information owner (C-2); the authorizing official or a designated representative approves the categorization (C-3). In the JSIG, the ISO categorizes with the ISSM/ISSO and ISSE (Task 1-1).

- NIST C-1 · System description
- NIST C-2 · Security categorization
- NIST C-3 · Security categorization review and approval
- JSIG Task 1-1 · Categorize the system and document the results in the SSP
- JSIG Task 1-2 · Describe the system, including its boundary, and document it in the SSP
- JSIG Task 1-3 · Register the system with the appropriate SAP Service/Agency AO or designee

What this module produces

- A documented system description in the draft SSP (C-1; JSIG Task 1-2)
- Impact levels for each information type and security objective, with a written rationale (C-2)
- The system's security categorization recorded in the draft SSP (C-2; JSIG Task 1-1)
- The categorization routed to the authorizing official or a designated representative for approval (C-3)
- The module 02 registration checked against the JSIG route (Task 1-3)

JSIG step outputs Draft SSP; System registration

WHERE THE JSIG AND NIST DIFFER NIST registers the system in Prepare (P-18) and describes it here (C-1). The JSIG describes the system and its boundary (Task 1-2) and registers it (Task 1-3) in this step.

Learn

03.1 System description Describe the system someone else will assess.

Categorize opens with a system description (C-1): what the system is for, what it contains, who uses it, what it connects to, and where its boundary lies, drawn from the Prepare records. The JSIG asks for the same in Task 1-2: describe the system, including its boundary, in the System Security Plan (SSP).

Write it so a reviewer who has never seen the system can follow it. Every later decision, from categorization to control selection, points back to this description.

03.2 Impact and rationale Evaluate the consequences for each objective.

Confidentiality concerns inappropriate disclosure, integrity improper change, and availability reliable access when needed. For each information type, judge the impact of a loss on each objective, then set the system's impact for each objective from those results (C-2), using the method that applies.

© 2026 Secure By Design Team LLC.

In the JSIG, the ISO categorizes the system with the ISSM or ISSO and the ISSE, and documents the results in the SSP (Task 1-1). Write a rationale someone else can review: the information, what's affected, the consequence, and why each level fits. An isolated network alone doesn't decide the result.

03.3 Authority, approval, and registration Apply the right authority, then get approval.

Federal systems categorize under Federal Information Processing Standard (FIPS) 199 with the information types in NIST SP 800-60; national security systems follow CNSSI 1253, and a SAP adds its program direction. Treat privacy applicability as an explicit decision.

NIST makes approval a task of its own (C-3): the authorizing official or a designated representative approves the categorization. In the JSIG, the categorization is documented in the draft SSP, and the whole plan is approved in Select (Task 2-4). This JSIG step also registers the system (Task 1-3), which NIST did in Prepare (P-18).

Worked example: A new dependency reopens availability

1. **Initial rationale —** Engineering work can wait out a short outage of the internal web application, so the exercise input rates availability Low.
2. **New information —** A deadline-driven engineering process now depends on timely access to the application on SBD-WEB01 and its records in SBD-SQL01.
3. **Review —** Reevaluate the availability consequences for those information types under the applicable method (C-2).
4. **Update —** Record the new rationale in the draft SSP and the scope record's categorization basis, route it for approval (C-3), and update the registration if the category changes.

Build

Draft the SSP's system description and security categorization from the scope record: information types, impact rationale, mission dependencies, privacy considerations, and approval routing. Justify the exercise planning input (Moderate confidentiality, Low integrity, Low availability); don't copy it. Complete the scope record's categorization basis and confirm the registration follows JSIG Task 1-3.

Practice artifacts System Security Plan; System scope record (see Evidence starters)

Think it through

Defend a changed availability impact after a new mission dependency, and explain why an air gap alone doesn't establish a low impact level. Then say who approves the categorization in NIST terms and where the JSIG documents it.

Check your understanding

The system owner has categorized the system and wants to start selecting controls. What does NIST SP 800-37 Revision 2 call for first?

- A. Nothing more. The system owner's categorization is final.

- B. Review and approval of the categorization by the authorizing official or a designated representative (C-3).
- C. A control assessment by the security control assessor.

Your record

RECORD	YOUR OBSERVATION
System Security Plan — location and version	
System scope record — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Categorization starts with the information: business files and databases on VLAN 40, the identities in the directory, and the audit record on VLAN 50. Availability follows the mission processes that depend on them.

[1] NIST SP 800-37 Revision 2

[4] NIST SP 800-53B

[5] DoDI 8510.01

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Select controls and plan monitoring

WHY THIS MATTERS Turn the approved categorization into a selected, tailored, and allocated control set, with a draft Risk Assessment Report and a continuous monitoring strategy, ready for plan review and approval.

The RMF step

Who does the work The system owner and any common control provider select, tailor, and document the controls and the monitoring strategy (S-1, S-2, S-4, S-5); security architects and the system security officer allocate them (S-3); the authorizing official or a designee approves the plan (S-6). In the JSIG, the ISO does Tasks 2-1 to 2-3 with the ISSE and/or ISSM/ISSO; the AO, SCA, or AO designee approves (2-4).

- NIST S-1 · Control selection
- NIST S-2 · Control tailoring
- NIST S-3 · Control allocation
- NIST S-4 · Documentation of planned control implementations
- NIST S-5 · Continuous monitoring strategy—system
- NIST S-6 · Plan review and approval
- JSIG Task 2-1 · Identify common controls and document them in a security plan
- JSIG Task 2-2 · Select the security controls for the information system and document the controls in the security plan
- JSIG Task 2-3 · Develop a strategy for continuous monitoring of security control effectiveness
- JSIG Task 2-4 · Review and approve the SSP

What this module produces

- Selected and tailored controls, with parameters and rationale, in the SCTM (S-1, S-2)
- Controls allocated to the system, its components, or a common control provider (S-3; JSIG Task 2-1)
- Planned implementations documented in the security plan and SCTM (S-4; JSIG Task 2-2)
- A draft Risk Assessment Report built from the early risk picture and the planned controls (JSIG Step 2 output)
- A system continuous monitoring strategy, including reporting and decommissioning (S-5; JSIG Task 2-3)
- The plan routed for review and approval (S-6; JSIG Task 2-4)

JSIG step outputs Updated draft SSP/SCTM; Draft Risk Assessment Report (RAR); Documented Continuous Monitoring (ConMon) Plan/Strategy; Approved draft SSP/SCTM

WHERE THE JSIG AND NIST DIFFER The JSIG produces a draft RAR in this step and updates it in Assess; NIST assesses system risk in Prepare (P-14) and analyzes and determines it in Authorize (R-2).

Learn

04.1 Baselines, overlays, and tailoring A catalog is not the same as a selected control set.

© 2026 Secure By Design Team LLC.

SP 800-53 is a catalog; a baseline is a starting set under a selection method, and overlays can change it. SP 800-53B holds the federal baselines; a national security system selects under CNSSI 1253 and its overlays, and a SAP adds the JSIG and approved program direction.

Select the controls (S-1), then tailor them (S-2): record why each is added, adjusted, or not applicable, resolve organization-defined parameters such as roles and frequencies, and note who approves. Difficulty alone doesn't make a requirement not applicable.

04.2 Allocation and the security plan Allocate the work before asking for evidence.

Allocate each control to the system, its components, or its environment (S-3), and name its owner: system-specific, common from a provider, or hybrid with shared responsibility. The JSIG begins Select here, with Task 2-1: identify the common controls and document them in a security plan.

Then document the planned implementations (S-4). The JSIG's Task 2-2 selects the controls and documents them in the security plan. A Security Controls Traceability Matrix (SCTM) can record each control's selection, parameters, allocation, and inheritance; its format follows local requirements.

04.3 Risk, monitoring, and plan approval Plan how you'll know it still works, then get approval.

A system continuous monitoring strategy (S-5; JSIG Task 2-3) says which controls are monitored, how often, by whom, and what triggers action, within the organization's strategy (P-7). The JSIG also drafts a Risk Assessment Report (RAR) here; NIST assessed system risk in Prepare (P-14).

Then the plan is reviewed and approved: by the authorizing official or a designated representative in NIST (S-6), or by the AO, SCA, or AO designee in the JSIG (Task 2-4). The JSIG calls the result the approved draft SSP/SCTM.

Worked example: Credentialed scanning isn't built yet

1. **Proposal —** "Mark RA-5 not applicable until a credentialed scanner exists."
2. **Question —** Is the control inapplicable, or only hard to meet today? The network still runs software that needs vulnerability monitoring.
3. **Decision —** Keep RA-5 selected. Allocate what exists, SCAP Compliance Checker and Security Technical Implementation Guide (STIG) results from the administration seats, and record credentialed scanning as a gap.
4. **Record —** The SCTM row shows the allocation and the gap, the draft RAR carries the risk, and the monitoring strategy reviews scan coverage.

Build

Start the Security Controls Traceability Matrix (SCTM) with each selected control's adopted revision, source, tailoring rationale, parameters, owner, and system-specific, common, or hybrid allocation. Draft the Risk Assessment Report (RAR) from the module 02 risk picture, write the continuous monitoring strategy, and route the plan for approval.

Practice artifacts Security Controls Traceability Matrix; Risk Assessment Report; Continuous monitoring strategy (see Evidence starters)

Think it through

Resolve a proposed not-applicable control and an inherited-control claim using evidence and the required approval path. Show which monitoring activity watches each draft RAR risk, and pin the control and assessment-procedure versions.

Check your understanding

A facility office says physical access to the server room is “covered.” What does the SCTM need before the plan goes for approval?

- A. Nothing more. Mark PE-3 inherited on the provider’s word.
- B. Mark PE-3 not applicable, since the system team doesn’t run the building.
- C. The provider, the parts it performs, its assessment information, and what the system team still does.

Your record

RECORD	YOUR OBSERVATION
Security Controls Traceability Matrix — location and version	
Risk Assessment Report — location and version	
Continuous monitoring strategy — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Each practice control lands on real systems: account management (AC-2) on the domain controllers, audit (AU-2, AU-6, AU-12) on the collector and VLAN 50, and flaw remediation (SI-2) through SBD-WSUS01 and SBD-REPO01. The traceability matrix records who implements each one.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[3] NIST SP 800-53A Revision 5

[4] NIST SP 800-53B

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Evidence starters

Blank starters for the practice artifacts this course produces. Fill them from your own system. The interactive course shows a completed fictional example of each, and the training materials download includes each one as Markdown (and CSV for tables).

System scope record

Prepare outputs Owner: System owner (ISO) with the security team. Agree on the roles, governing direction, mission, boundary, information, early risks, and requirements before the package grows. Module 01 starts it, module 02 completes the Prepare fields, and module 03 adds the categorization basis.

FIELD	YOUR ENTRY
Roles and governing direction — Who holds each role, in NIST and JSIG terms; the governing documents, their editions, and the adopted control release.	
Mission and stakeholders — Missions and business processes the system supports (P-8); everyone with an interest in it (P-9).	
Assets and boundary — Assets to protect (P-10); the authorization boundary the AO determines (P-11), with management paths, shared services, and external dependencies.	
Information types and life cycle — Information the system processes, stores, and transmits (P-12), and each type’s path from creation to disposal (P-13), including boundary transfers.	
Early risk picture — The first system risk assessment (P-14): threats, weaknesses or conditions, likely consequences, and assumptions. Module 04 carries it into the draft Risk Assessment Report (RAR).	

© 2026 Secure By Design Team LLC.

FIELD	YOUR ENTRY
Requirements and allocation — Security and privacy requirements (P-15), the system's place in the architecture (P-16), and where each requirement lands (P-17), including candidate common controls.	
Categorization basis — Method and authority, the information types considered, and where the result is recorded and approved. Completed in module 03.	

The scope record is an exercise starter. The relevant authority determines the formal boundary, categorization, and approval requirements.

System registration

Registration record Owner: System owner (ISO). Register the system with the office the organization or program designates, so it is known, tracked, and accountable before the package grows. NIST registers in Prepare (P-18); the JSIG in Categorize (Task 1-3).

FIELD	YOUR ENTRY
System identity — Name, registration number, owner, and points of contact.	
Registered with — The office the organization designates (NIST P-18) or, for a Special Access Program (SAP) system, the appropriate SAP Service/Agency Authorizing Official (AO) or designee (JSIG Task 1-3).	
Purpose and characteristics — The mission in a sentence or two, location, connections, and operating status.	
Boundary summary — What the authorization covers, with a reference to the documented boundary.	

FIELD	YOUR ENTRY
Categorization and plan status — The approved security categorization, the System Security Plan reference, and the authorization status.	
Update triggers — Changes that require an update to the registration.	

A fictional exercise record. The registering office, the required content, and the format follow the organization’s or program’s policy.

System Security Plan

System description to as-built controls Owner: System owner with the security team and engineers. Describe the system and its categorization, record the plan’s approval, and explain how each selected control is implemented.

FIELD	YOUR ENTRY
System description — Name, identifier, mission, boundary, components, environment, and references (NIST C-1; JSIG 1-2).	
Security categorization — Information types; confidentiality, integrity, and availability impacts with rationale; method; reviewer; approval (C-2, C-3; JSIG 1-1).	
Plan review and approval — Version reviewed, reviewer and role, date, decision, and any conditions (S-6; JSIG 2-4).	
As-implemented control statements — Control ID and adopted revision, approved parameters (from the SCTM), and who does what, where, when, and with which records (I-2; JSIG 3-2).	
Evidence and responsibilities — Evidence identifiers, owners, provider dependencies, and review status.	

FIELD	YOUR ENTRY
Limitations and planned work — Separate what operates from planned work and known gaps.	
Recorded risk decisions — Risk responses, rationale, mitigation, decision owner, and review trigger.	

The example is an excerpt, not a full SSP or a finding of compliance. In the JSIG, the SSP also includes the SCTM, the continuous monitoring strategy, and a Risk Assessment Report; this course keeps them as separate practice artifacts.

Security Controls Traceability Matrix

Requirement to implementation Owner: System owner (ISO) and security team, with implementation owners. Record each selected control's source, tailoring, parameters, allocation, and inheritance, then trace it to implementation, evidence, and results. Started in Select; module 05 adds the as-implemented statements.

CONTROL	SELECTION AND TAILORING	PARAMETERS	ALLOCATION AND INHERITANCE	IMPLEMENTATION AND TRACE
[ID / title / adopted revision]	[Baseline or overlay source; tailoring decision, rationale, approval]	[Organization-defined values and their source]	[System-specific, common, or hybrid; provider and what it supplies; components; owner]	[Planned (module 04), then as implemented (module 05); evidence, result, and finding IDs]

Mappings are instructional. Expand rows to the exact selected control parts and assessment objectives; a single record doesn't prove an entire control. In the JSIG, the SCTM is part of the System Security Plan.

Risk Assessment Report

Risk analysis Owner: System owner (ISO) with the ISSM and ISSO. Record the risks that remain with the selected controls, how likely and harmful each is, and what the assessment must confirm. Drafted in Select as a JSIG Step 2 output; module 08 updates it with assessment results.

RISK	PLANNED SAFEGUARDS	LIKELIHOOD AND IMPACT	RISK LEVEL	RESPONSE AND NEXT UPDATE
[RSK-ID: threat event, the weakness or condition it exploits, and what it affects]	[Selected controls from the Security Controls Traceability Matrix (SCTM) that address it]	[Ratings and reasons, using the authority's method and scale]	[Result, confidence, and assumptions]	[Planned response and owner; what the assessment must confirm (module 08)]

Ratings are exercise values, not an assessment of any real system; use the method and scale your authority directs. In the JSIG's authorization package, the System Security Plan includes a RAR (Task 5-2). Only the AO accepts risk.

Continuous monitoring strategy

Maintain the authorization basis Owner: System owner (ISO) with control owners; approved by the Authorizing Official (AO). Define what is monitored, how often, by whom, and what triggers action, so the authorization basis stays current. Written in Select (S-5; JSIG Task 2-3) and run in module 12.

ACTIVITY	OWNER	FREQUENCY / TRIGGER	EVIDENCE AND ESCALATION
[Monitoring activity and the NIST and JSIG task it serves]	[Role]	[Frequency or trigger approved in the strategy]	[Record produced / threshold / action]

Frequencies and thresholds are dependent on your environment and set by the applicable direction and system risk; this example doesn't prescribe universal intervals. Module 12 runs the strategy and records each security impact analysis.

Knowledge check answers

01 Your program directs the public JSIG of 11 April 2016. Which statement fits it?

C. It follows SP 800-37 Revision 1's six steps, starting at Categorize, with SP 800-53 Revision 4 and CNSSI 1253. NIST is the foundation; the JSIG is SAP-specific direction for applying it. The 2016 edition predates the Revision 2 Prepare step and the Revision 5 controls, and your program may direct a successor.

02 Your program follows the 2016 JSIG, which has no Prepare step. Where does the boundary and registration work happen?

A. In Categorize: describe the system and its boundary (Task 1-2), then register it (Task 1-3). The JSIG follows SP 800-37 Revision 1, so work that NIST Revision 2 puts in Prepare (P-11, P-18) appears in the JSIG's Categorize step.

03 The system owner has categorized the system and wants to start selecting controls. What does NIST SP 800-37 Revision 2 call for first?

B. Review and approval of the categorization by the authorizing official or a designated representative (C-3). The system owner and information owner categorize (C-2); approval is a separate task (C-3). In the JSIG, the categorization is documented in the draft SSP (Task 1-1), and the plan is approved in Select (Task 2-4).

04 A facility office says physical access to the server room is "covered." What does the SCTM need before the plan goes for approval?

C. The provider, the parts it performs, its assessment information, and what the system team still does. An inherited or hybrid allocation needs an identified provider and applicable evidence. Record the split in the SCTM so the assessor knows what to ask of whom.

© 2026 Secure By Design Team LLC.

Sources

Choose the applicable authority and record the adopted versions before using a template. Module reference numbers correspond to these documents.

[1] NIST SP 800-37 Revision 2

RMF lifecycle, tasks and outputs, authorization package, roles, and monitoring. See Chapter 3 and Appendix E.

[2] NIST SP 800-53 Revision 5

Security and privacy control catalog. Record the release adopted by the governing authority.

[3] NIST SP 800-53A Revision 5

Control assessment procedures and examine, interview, and test methods.

[4] NIST SP 800-53B

Control baselines, tailoring, and overlays. Apply the appropriate system context.

[5] DoDI 8510.01

Risk Management Framework for DoD Systems, July 19, 2022.

[6] DoDM 5205.07

Special Access Program Security Manual, January 17, 2025.

[7] DCSA Voice of Industry · September 2025

DCSA newsletter for cleared industry on the DAAG transition. Confirm the current guide, version, and effective date with DCSA.

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

The six RMF steps, tasks, and outputs for Special Access Program (SAP) systems, built on NIST SP 800-37 Revision 1, SP 800-53 Revision 4, and CNSSI 1253 (March 2014). Confirm whether your program directs it or a successor.

© 2026 Secure By Design Team LLC.

Course review and sign-off

Before moving on, confirm each module left its outputs behind — and that what remains open is written down.

Module completion

MODULE	OUTPUTS FILED	DATE
01 RMF roles, steps, and editions	☐ yes	
02 Define and register the system	☐ yes	
03 Describe and categorize the system	☐ yes	
04 Select controls and plan monitoring	☐ yes	

Open items carried forward

Next in the learning path

That completes Risk Management Framework. Course 2.2, Body of Evidence, implements and assesses the controls you selected, starting from these outputs.

> **KEEP IT HONEST** Course completion records learning activity. It is not a system authorization, an assessment result, or an approval by any authorizing official. Exercise records are fictional.

© 2026 Secure By Design Team LLC.